



بنك الآفاق

AL-AFAQ BANK

Global Horizon Banking | آفاق عالمية | سلامة استثمارية .. وآفاق عالمية

## إجراءات التشغيل الأمنية (SECURITY OPERATING PROCEDURE)

إجراءات التشغيل الأمنية لإدارة تقنية المعلومات (النسخ الاحتياطي، التشفير، التوقيع، وإدارة الثغرات)

اسم الإجراء  
(Procedure Name)

| الإصدار | معتمد من                                                             | مالك الإجراء                                  | تاريخ آخر تحديث | دورية المراجعة | المراجعة القادمة | الملاحظات                                                                                                                                                          |
|---------|----------------------------------------------------------------------|-----------------------------------------------|-----------------|----------------|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.0     | د. نورة القحطاني<br>(الرئيس التنفيذي)<br>م. فهد العتيبي<br>(مدير IT) | أ. سارة الحربي<br>(مدير أمن المعلومات - CISO) | 09-2026<br>11   | سنوي           | سبتمبر 2027      | أدلة التشغيل الأمنية الموحدة لإدارة تقنية المعلومات لبنك الآفاق الرقمية وفق الضابط A.5.37 لـ ISO 27001 (إعداد: محمد العامري، محمد الكشري، محمد شماخ، محمد الأصبحي) |

التصنيف: سري

يجب قصر الاطلاع على هذا المستند على أولئك الذين لديهم حاجة محددة لذلك.

### 1. الغرض (Purpose)

تحدد هذه الوثيقة الإجراءات والخطوات التشغيلية الأمنية القياسية (SOP) لمهندسي وفنيي إدارة تقنية المعلومات وإدارة أمن المعلومات في بنك الآفاق الرقمية. تهدف الوثيقة إلى توحيد وضبط العمليات اليومية الحرجة، والحد من الأخطاء البشرية الفردية، وضمان استمرارية الخدمات المصرفية الرقمية وتوافرها بنسبة لا تقل عن 99.95%، بما يتوافق مع متطلبات الضابط A.5.37 من المواصفة الدولية ISO/IEC 27001:2022 وإطار الأمن السيبراني الصادر عن البنك المركزي السعودي (ساما).

تغطي هذه الوثيقة أربعة محاور تشغيلية أساسية لمعالجة الفجوات والحوادث السابقة المسجلة في البنك:

- إجراءات النسخ الاحتياطي والاستعادة واختبار التعافي من الكوارث (Backup & Recovery).
- إجراءات التشفير وإدارة المفاتيح ومراقبة شهادات الأمان الرقمية (Cryptography & SSL/TLS Management).

- إجراءات إدارة التحديثات والترقيع وضبط التغييرات التشغيلية (Patch Management & Change Control).
- إجراءات إدارة وفحص ومعالجة الثغرات التقنية (Technical Vulnerability Management).

## 2. النطاق (Scope)

- يسري هذا الإجراء بشكل إلزامي على كافة الأصول والأنظمة والبيئات التقنية التابعة لبنك الآفاق الرقمية، وتشمل:
- النظام المصرفي الأساسي (Core Banking System)، ونظام إدارة البطاقات (CMS)، ونظام المدفوعات الفورية (IPS).
  - تطبيق الهاتف المحمول 'آفاق بلس' (iOS و Android)، وبوابة الخدمات الإلكترونية عبر الإنترنت 'آفاق نت'.
  - خوادم قواعد البيانات العنقودية (Oracle RAC) لقواعد العملاء والمعاملات، وخوادم SQL Server للموارد البشرية.
  - بيئات التشغيل الافتراضية (VMware vSphere) تضم أكثر من 200 خادم افتراضي و40 خادماً فيزيائياً.
  - أجهزة الشبكات وأمن المحيط: جدران الحماية الرئيسية (Palo Alto)، جدران حماية تطبيقات الويب (Fortinet FortiWeb)، وموجهات Cisco ASR.
  - الأجهزة الطرفية: عدد 2,000 حاسوب محمول (HP EliteBook)، و500 حاسوب مكتبي، و150 جهاز صراف آلي (ATM).
  - المواقع الفيزيائية والسحابية: مركز البيانات الرئيسي (الرياض - الطابق 3)، مركز التعافي من الكوارث (جدة)، و25 فرعاً مصرفياً، وبيئات التطوير والاختبار المستضافة على Amazon Web Services (AWS).

## 3. الأدوار والمسؤوليات (Roles and Responsibilities)

- تتوزع مسؤوليات تنفيذ وإشراف هذه الإجراءات التشغيلية على النحو التالي:
- مدير تقنية المعلومات - CIO (م. فهد العتيبي): الإشراف العام على تنفيذ الإجراءات التشغيلية وتوفير الموارد التقنية والتأكد من التزام مهندسي IT بتطبيق خطوات الصيانة والترقيع دون الإخلال باتفاقيات مستوى الخدمة (SLA).
  - مدير أمن المعلومات - CISO (أ. سارة الحربي): التحقق والرقابة المستقلة على مطابقة إجراءات التشغيل للسياسات الأمنية وضوابط ساما، وإدارة فحوصات الثغرات، ومراقبة الشهادات الرقمية ومفاتيح التشفير.
  - قسم البنية التحتية وقواعد البيانات: تنفيذ عمليات النسخ الاحتياطي عبر Veritas NetBackup، مزامنة النسخ المتماثلة لموقع جدة، وتطبيق الترقيع الأمني وإعدادات التحصين على خوادم ومستودعات التخزين SAN.
  - قسم الشبكات والاتصالات: تنفيذ التغييرات المزدوجة على جدران الحماية Palo Alto، مراقبة اتصالات الفروع والـ DR، وضبط التوجيه ومزامنة خادم NTP المركزي.
  - قسم تطوير البرمجيات (25 مطوراً): معالجة ثغرات الكود (خاصة ثغرات SQLi في آفاق بلس)، الالتزام بإجراءات الفحص الأمني في GitLab، وفصل بيئات التطوير عن الإنتاج.
  - قسم الدعم الفني (Service Desk): تفعيل التشفير الكامل للأقراص (BitLocker) لـ 2,000 لابتوب، تثبيت تحديثات الأجهزة الطرفية، والتحقق من سلامة مكافحة الفيروسات Trend Micro.
  - فريق العمليات الأمنية (8 - SOC محللين): المراقبة والتحليل اللحظي للسجلات على مدار 7/24، تتبع محاولات التسلل، ورصد الإنذارات المبكرة لانتهاج شهادات SSL أو فشل النسخ الاحتياطي.
  - الفريق الاستشاري: أعضاء فريق المشروع (محمد العامري، محمد الكشري، محمد شماخ، محمد الأصبحي) بتوثيق الإجراءات ومواءمتها مع الملحق A لمواصفة ISO 27001:2022.

## 4. الإجراءات والخطوات التشغيلية القياسية (Procedure)

تحدد الخطوات أدناه الآلية الإلزامية لتنفيذ العمليات التشغيلية الأربع الرئيسية في بنك الآفاق الرقمية:

### الإجراء الأول: إجراءات النسخ الاحتياطي والاستعادة (Backup & Recovery Procedure)

يهدف هذا الإجراء إلى ضمان توفر وحماية البيانات المصرفية والمعاملات ضد التلف أو هجمات الفدية، وفق استراتيجية 1-2-3:

- الخطوة 1: جدولة النسخ الاحتياطي اليومي: تنفيذ نسخ احتياطي تزايد (Incremental Backup) يومياً لكافة خوادم التطبيقات والملفات، ونسخ تراكمي لسجلات المعاملات المالية (Archive Logs) لقواعد بيانات Oracle كل ساعتين آلياً عبر برنامج Veritas NetBackup.
- الخطوة 2: النسخ الكامل الأسبوعي والتشفير: تنفيذ نسخ احتياطي كامل (Full Backup) أسبوعياً في عطلة نهاية الأسبوع (مساء الجمعة) لقواعد بيانات العملاء والمعاملات والنظام المصرفي الأساسي، مع تشفير كافة النسخ الاحتياطية باستخدام خوارزمية AES-256.
- الخطوة 3: التكرار الجغرافي إلى مركز جدة: مزامنة النسخ الاحتياطية تلقائياً عبر خطوط الألياف البصرية المزدوجة والمؤمنة التابعة لـ STC إلى مكتبة الشرطة وخوادم مركز التعافي من الكوارث (DR Site) بجدة لتحقيق العزل الجغرافي (950 كم).
- الخطوة 4: اختبارات الاستعادة والجاهزية: تنفيذ اختبار استعادة دوري شهري لعينة عشوائية من النسخ الاحتياطية في بيئة اختبار معزولة، وإجراء محاكاة تعافي نصف سنوية كاملة لتشغيل الأنظمة من موقع جدة لضمان تحقيق RTO أقل من 30 دقيقة و RPO يقارب الصفر.

### الإجراء الثاني: إدارة التشفير والشهادات الرقمية (Cryptography & Certificate Management)

يهدف هذا الإجراء إلى منع تسريب بيانات العملاء وحل أزمة انتهاء شهادة SSL التي عطلت الموقع سابقاً:

- الخطوة 1: تشفير الأجهزة المحمولة والطرفية: معالجة حادثة لايتوب التسويق: تفعيل تشفير الأقراص الصلبة بالكامل (BitLocker باقتراح TPM 2.0 ومفتاح AES-256) على جميع الحواسيب المحمولة المسلمة للموظفين (2,000 جهاز) قبل تسليمها، وحفظ مفاتيح الاسترداد مركزياً في Active Directory.
- الخطوة 2: تشفير قواعد البيانات أثناء التخزين: تفعيل التشفير الشفاف لقواعد البيانات (Oracle TDE) لتشفير الجداول الحاوية لبيانات العملاء وأرقام بطاقات الائتمان، وإدارة المفاتيح عبر وحدة أمان العتاد (HSM).
- الخطوة 3: أتمتة مراقبة وتجديد شهادات SSL/TLS: معالجة حادثة انتهاء شهادة SSL السابقة: إدراج كافة الشهادات الرقمية لبوابة 'آفاق نت' والتطبيقات في نظام مراقبة آلي يرسل تنبيهات مبكرة عند بقاء 60 يوماً و 30 يوماً و 14 يوماً على الانتهاء لمهندسي البنية التحتية والـ SOC لضمان التجديد والاختبار قبل الانتهاء بـ 30 يوماً على الأقل.
- الخطوة 4: فرض بروتوكولات النقل الآمن: سد فجوة الملحق A.8.21: إلغاء وتعطيل بروتوكولات التشفير القديمة (SSLv3, TLS 1.0)، (TLS 1.1) على جميع خوادم الويب والجدران النارية، وإلزام استخدام TLS 1.2 و TLS 1.3 مع حزم التشفير القوية فقط.

### الإجراء الثالث: إدارة التحديثات وضبط التغييرات (Patch Management & Change Control)

يهدف هذا الإجراء لمعالجة السبب الجذري لحادثة انقطاع الخدمات لـ 3 ساعات وقت الرواتب:

- الخطوة 1: تقييم التحديثات الأمنية المصدرة: متابعة النشرات الأمنية وتصنيف التحديثات الصادرة من الموردين (Microsoft, Oracle, Palo Alto, Cisco, VMware) وفق درجات الخطورة (حرجة، عالية، متوسطة، منخفضة).
- الخطوة 2: الاختبار الإلزامي في بيئة التأهيل: تثبيت واختبار التحديثات وإعدادات جدران الحماية أولاً في بيئة الاختبار والتأهيل (Staging Environment) لمدة لا تقل عن 72 ساعة للتحقق من عدم تعارضها مع العمليات المصرفية.
- الخطوة 3: الموافقة المزدوجة على التغييرات الحرجة: فرض مبدأ الموافقة المزدوجة (Four-Eyes Principle) الصارم: حظر تطبيق أي تعديل في قواعد جدران الحماية أو إعدادات الشبكة من قبل مهندس منفرد؛ يلزم تقديم طلب تغيير عبر Jira ومراجعته واعتماده من مهندس شبكات أول وموافقة CISO ومدير IT.
- الخطوة 4: خطة التراجع الفورية ونوافذ الصيانة: إعداد وتوثيق خطة تراجع واضحة ومختبرة مسبقاً (Rollback Script) قبل البدء في تطبيق أي تغيير، مع تحديد نافذة صيانة خارج أوقات الذروة، والتنفيذ الفوري لخطة التراجع في حال حدوث أي شذوذ أو انقطاع خلال 15 دقيقة.

## 5. الضوابط الأمنية المطبقة (Security Controls)

يرتبط هذا الإجراء التشغيلي بحزمة من ضوابط الملحق A لمواصفة ISO/IEC 27001:2022:

- الضابط A.5.37 (إجراءات التشغيل الموثقة): توثيق إجراءات التشغيل لضمان اتساق وسلامة إدارة مرافق المعالجة.
- الضابط A.8.8 (إدارة الثغرات الفنية): ضبط دورة الفحص والمعالجة والترقيع خلال 14 يوماً للثغرات الحرجة.
- الضابط A.8.9 (إدارة التهينة والتحصين): تطبيق إعدادات التحصين القياسية وفق CIS Benchmarks ومنع التكوينات الافتراضية.
- الضابط A.8.13 (النسخ الاحتياطي للمعلومات): تطبيق سياسة النسخ الاحتياطي المشفر والتكرار إلى مركز جدة واختبار الاسترجاع.
- الضابط A.8.21 و A.8.16 (أمن خدمات الشبكة والمراقبة): أتمتة مراقبة شهادات SSL وإلغاء بروتوكولات التشفير المتقدمة TLS 1.1/1.0.
- الضابط A.8.24 (استخدام التعمية والتشفير): فرض التشفير الشامل BitLocker و Oracle TDE و AES-256.
- الضابط A.8.32 (إدارة التغيير): الموافقة المزدوجة (Four-Eyes) واشتراط خطط التراجع المكتوبة على تغييرات الشبكات.

## 6. إدارة الحوادث التشغيلية (Incident Management)

- في حال حدوث أي فشل تشغيلي، أو انقطاع غير مخطط له للخدمة، أو اكتشاف ثغرة صفرية (Zero-Day)، تتبع الخطوات التالية فوراً:
- الكشف والإبلاغ الفوري: إشعار فوري لمركز العمليات الأمنية (SOC) ومكتب الدعم الفني عبر الخط الساخن المخصص للحوادث، وتصنيف الحادث وفق مصفوفة الخطورة.
  - الاحتواء والعزل: تطبيق إجراءات الاحتواء الفورية (مثل عزل الخادم المتأثر شبكياً، أو تفعيل خطة التراجع لإعدادات الجدار الناري، أو تحويل المسارات).
  - تفعيل خطة الطوارئ والتعافي: في حال تجاوز الانقطاع 30 دقيقة للأنظمة الحرجة، يتم تفعيل خطة استمرارية الأعمال والتحويل إلى مركز التعافي من الكوارث بجدة (DR Site).
  - الإبلاغ التنظيمي لساما: إشعار البنك المركزي السعودي (ساما) خلال ساعتين كحد أقصى في حال الحوادث التشغيلية أو السيبرانية الجسيمة وفق اللوائح الإلزامية.
  - التحقيق والدروس المستفادة: إجراء تحقيق جنائي رقمي وتحليل السبب الجذري (RCA) خلال 48 ساعة من احتواء الحادث، وتوثيق الدروس المستفادة لمنع تكرار الخطأ.

## 7. المراقبة والتدقيق (Monitoring and Auditing)

تخضع كافة العمليات التشغيلية لمراقبة وتدقيق مستمر لضمان الالتزام الصارم:

- مزامنة التوقيت المركزي (NTP Synchronization): معالجة الفجوة الموثقة بالملحق A.8.17: إلزامية ربط كافة خوادم البنك، وجدران الحماية، وأجهزة الشبكة بخادم توقيت مركزي (NTP) موحد ومعتمد لمنع أي تفاوت زمني (حل فارق الـ 7 دقائق السابق) وضمان سلامة السجلات الجنائية.
- تسجيل ومراقبة الأحداث (Centralized Logging): إرسال كافة سجلات أحداث النسخ الاحتياطي، والتغييرات الإدارية، وعمليات الترقيع إلى خادم السجلات المركزي (Syslog Server) ومراقبتها عبر الـ SOC على مدار الساعة.
- التدقيق الداخلي الدوري: تنفيذ مراجعة تدقيق ربع سنوية مستقلة من قِبل إدارة المراجعة الداخلية وفريق الحوكمة للتحقق من تنفيذ إجراءات الترقيع والنسخ الاحتياطي ومراجعة الصلاحيات.

## 8. المراجعة والتحديث (Review and Update)

تتم مراجعة وتحديث هذه الوثيقة التشغيلية سنوياً بصفة دورية، أو فور تحقق أي من الحالات التالية:

- إدخال أنظمة مصرفية أو منصات برمجية جديدة ضمن بيئة البنك.
- وقوع حادث أمني أو انقطاع تشغيلي جسيم كشف عن ثغرة في إجراءات التشغيل.
- صدور تعليمات أو أطر تنظيمية جديدة من البنك المركزي السعودي (ساما) أو الهيئة الوطنية للأمن السيبراني (NCA).
- تعتمد أي تعديلات على هذه الإجراءات بموافقة مشتركة من مدير أمن المعلومات (CISO) ومدير تقنية المعلومات (CIO).

## 9. المراجع والوثائق ذات الصلة (References)

- المواصفة القياسية الدولية ISO/IEC 27001:2022 (الضوابط A.5.37, A.8.8, A.8.9, A.8.13, A.8.16, A.8.17, A.8.21, A.8.24, A.8.32).
- إطار الأمن السيبراني الصادر عن البنك المركزي السعودي (SAMA Cyber Security Framework).
- نظام حماية البيانات الشخصية الصادر عن الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA PDPL).
- سياسة أمن المعلومات العامة لبنك الآفاق الرقمية (ISMS-DOC-05-4).
- خطة استمرارية الأعمال والتعافي من الكوارث لبنك الآفاق الرقمية (ISMS-BCP-DRP).
- أدلة التحصين الأمني القياسية الصادرة عن مركز أمن الإنترنت (CIS Benchmarks).
- معيار المعهد الوطني للمعايير والتقنية لإدارة التحديثات (NIST SP 800-40 Guide to Enterprise Patch Management).